Nmap 6 Cookbook
Study Notes

The Fat-Free Guide to Network Security Scanning

Based on the book by Nicholas Marsh (2015, covers Nmap 6.47, Nping and Ncat)

Contents

0	Internet Protocol Suite overview
1	Installing Nmap
2	Basic scanning techniques
3	Discovery options
4	Advanced scan types
5	Port scanning options
6	OS and service detection
7	Timing options
8	Evading firewalls
9	Output options
10	Troubleshooting and debugging
11	Zenmap (GUI)
12	Nmap Scripting Engine (NSE)
13	Ndiff
14	Nping
15	Ncat
16	Tips and tricks
+	Quick cheat sheet and revision questions

> **WARNING** Only scan networks you own or have explicit permission to scan. Unauthorised scanning can get you in trouble with your ISP, the police and even the government, and aggressive scans can cause downtime or data loss on fragile systems. The book's practice target is **scanme.nmap.org**, which the Nmap project allows people to scan politely.

SECTION 0

Internet Protocol Suite Overview

Nmap works by crafting and analysing TCP/UDP/IP packets, so a basic grasp of TCP/IP is needed first.

History and key facts

- TCP/IP grew out of the US DoD's **ARPANET**, a **packet-switched** network (data is split into small packets and relayed). IPv4 was ratified in 1981.
- IPv4 gives about 4.3 billion addresses; **IPv6** uses 2^{128} addresses. There is no IPv5 (the number went to an experimental streaming protocol).
- The IP Suite moved responsibility for data integrity from the network to the hosts, which helped it scale.

TCP/IP model (4 layers)

Layer	Role	Examples
Application	Where programs run; hands requests to the OS TCP/IP stack	DNS, DHCP, HTTP, FTP, SMTP, IMAP, POP, SSH
Transport	Host-to-host communication; reliability (or lack of it)	TCP, UDP
Internet	Addressing and routing (routers, firewalls)	IPv4, IPv6, ICMP, IGMP
Link	Physical connection to local network (NICs, cables, switches)	Ethernet MAC, ARP, PPP, L2TP

The OSI 7-layer model is an alternative, stricter model that is compatible with TCP/IP.

Components of TCP/IP

Term	Meaning
IP address	Numeric (IPv4) or hexadecimal (IPv6) address identifying a device on a network.
Port	Numeric address for an application or protocol on a host. There are **65,535** ports.
Protocol	Defined syntax for communication (TCP, UDP, HTTP, SMTP, DNS...).
Segment / datagram	First stage of splitting data; created at the Transport layer (OSI layer 4). TCP makes segments, UDP makes datagrams.
Packet	Unit at the Internet layer (OSI layer 3); segments become packets.
Frame	Packets become frames when sent over the physical link (Ethernet header plus error-checking trailer).
Bit	The 1s and 0s sent over the link.

Encapsulation is the layering process: application data, then segment/datagram, then packet, then frame, then bits. Nmap lets you control fields in these headers to craft custom probes.

TCP versus UDP

	TCP	UDP
Type	Connection-oriented, reliable	Connectionless, less reliable
Mechanism	Sequence numbers, acknowledgments, windows	Simple header, no guaranteed delivery
Trade-off	More overhead	Less overhead and latency

Port ranges

- **0 to 1023:** well-known services.
- **1024 to 49151:** registered with IANA for vendor-specific applications.
- **49152 to 65535:** dynamic ports, mostly outbound client connections.

Common ports to memorise

Port	Service	Port	Service
`20 / 21`	FTP data / control (TCP)	143	IMAP
`22`	SSH	161 / 162	SNMP / SNMP trap
`23`	Telnet	389 / 636	LDAP / LDAPS
`25`	SMTP	443	HTTPS
`53`	DNS (TCP and UDP)	445	SMB
`67 / 68`	DHCP server / client (UDP)	873	RSYNC
`69`	TFTP (UDP)	993 / 995	IMAPS / POP3S
`80`	HTTP	1433	Microsoft SQL Server
`110`	POP3	3306	MySQL
`123`	NTP (UDP)	3389	RDP
`135`	Microsoft RPC	5800 / 5900	VNC web / VNC desktop
`137-139`	NetBIOS name / datagram / session		

SECTION 1

Installing Nmap

Linux is the ideal platform because of its networking stack, but Windows and Mac OS X are now well supported (Nmap 5 and newer). It also runs on Unix variants such as Solaris and BSD.

Platform	How to install
Windows	Download the installer from nmap.org, keep the default (full suite) install. It installs **WinPcap**, which is required; keep its service set to start at boot.
Debian / Ubuntu	sudo apt-get install nmap
Red Hat / Fedora	sudo yum install nmap
From source (Unix / Linux)	wget the .tgz, then: tar -xvf nmap-6.47.tgz; cd nmap-6.47/; ./configure && make; sudo make install
Mac OS X	Download the installer from nmap.org and use defaults. Nmap 6+ needs an Intel Mac (Nmap 5 was the last to support PowerPC).

- Verify the install with `nmap scanme.nmap.org`. Check the version with `nmap -V` (capital V).
- Repository versions may be old. Compile from source to get the newest features and fixes.
- Windows tip: PowerShell is easier than the Command Prompt because the window can be resized for wide output.

Command prompt conventions used in the book

Prompt	Meaning
C:\>	Windows
$	Unix / Linux / Mac, non-privileged user
#	Unix / Linux / Mac, root user
$ sudo	Elevated privileges (omit on Windows)

> **NOTE** Nmap options are **case sensitive**: -T2 is valid, -t2 is an error.

SECTION 2

Basic Scanning Techniques

- Firewalls, routers and proxies can **skew** results, especially when scanning remote hosts.
- Some scans need root or sudo.
- Scanning without permission is risky; aggressive scans can crash fragile systems.

Specifying targets

Goal	Command	Notes
Single target	nmap [target]	IP or hostname. Default scan checks the **top 1000 TCP ports**.
Multiple targets	nmap 192.168.1.1 192.168.1.109	Space-separated. Shorthand on one subnet: 192.168.1.1,109,155
Range	nmap 192.168.1.1-100	Wildcard * means 0-255. Example: 192.168.1-100.*
Whole subnet (CIDR)	nmap 192.168.1.1/24	/24 = 255.255.255.0 = 256 addresses
From a file	nmap -iL list.txt	Entries separated by space, tab or newline.
Random hosts	nmap -iR 3	Rarely useful; heavy use may get you banned by your ISP.
Exclude targets	nmap [targets] --exclude [targets]	Accepts hosts, ranges, CIDR blocks.
Exclude from file	nmap [targets] --excludefile list.txt	Protect systems you do not want to disturb.
Aggressive scan	nmap -A [target]	Combines OS detection, version/script scan (-O -sC) and traceroute.
IPv6	nmap -6 [target]	Ranges and CIDR do not apply to IPv6. All systems in the path must support IPv6.

Reading the output

Each result line has three fields: **PORT** (number/protocol), **STATE** and **SERVICE**. Ports are put in one of six states:

State	Meaning
`open`	Port actively responds to a connection.
`closed`	Responds to probes but no service is listening (common where no firewall filters).
`filtered`	Probably protected by a firewall, so Nmap cannot tell if it is open or closed.
`unfiltered`	Reachable, but Nmap cannot tell whether open or closed (seen with -sA).
`open|filtered`	Nmap believes open or filtered but cannot decide which.
`closed|filtered`	Nmap believes closed or filtered but cannot decide which.

Rules of thumb for interpreting remote scans

- **"The less expensive a connection is, the more problematic it will be for scanning."** Home broadband and free Wi-Fi are more likely to filter or tamper with traffic than a dedicated connection.
- **"The third port state is usually a suspect."** Normally you see only two states together (open/closed or open/filtered). Seeing open, closed and filtered together can indicate man-in-the-middle filtering. In the book's example, an ISP blocked ports 25, 135, 139 and 445, and a home router answered on 21, 554 and 7070, making them look open when they were not.

SECTION 3

Discovery Options

Before port scanning, Nmap pings the host so it can skip machines that are offline. By default it sends an ICMP echo request and also probes TCP ports 80 and 443, since ICMP is often blocked. The options below change how discovery is done.

Option	Name	What it does and when to use it
`-Pn`	Don't ping	Skip discovery and scan anyway. Use when a firewall blocks pings and Nmap says *Host seems down*. (Was -PN in Nmap 5.)
`-sn`	Ping-only scan	Find which hosts are up with no port scan. As root on a LAN it uses ARP and shows MAC addresses. (Was -sP.)
`-PS[ports]`	TCP SYN ping	Sends SYN, the first step of the 3-way handshake. Default port 80. Good when ICMP is blocked.
`-PA[ports]`	TCP ACK ping	Sends ACK to look like a reply to a non-existent connection. Default port 80.
`-PU[ports]`	UDP ping	Default port 40125. Poorly configured firewalls that only filter TCP may let it through.
`-PE`	ICMP echo ping	Standard ping. Implied by default. Works best on local networks.
`-PP`	ICMP timestamp ping	Some firewalls block echo but answer timestamp requests.
`-PM`	ICMP address mask ping	Unusual ICMP query that can sneak past echo-only filters.
`-PO[protos]`	IP protocol ping	Default protocols 1 (ICMP), 2 (IGMP), 4 (IP). Custom: -PO1,2,4
`-PR`	ARP ping	Fast and accurate on a LAN because hosts cannot block ARP. Automatic on the local subnet with root. Cannot cross subnets. Use --disable-arp-ping to try other methods on a LAN.
`--traceroute`	Traceroute	Shows each hop and round-trip time with reverse DNS. Generally faster and more accurate than traceroute/tracert.
`-n`	No reverse DNS	Speeds up scans by skipping reverse lookups. (-R forces them.)
`--system-dns`	System DNS resolver	Uses the OS resolver instead of Nmap's own. Slower, useful for troubleshooting DNS. Always used for IPv6.
`--dns-servers`	Custom DNS servers	Comma-separated list. Useful if no DNS is configured or to keep lookups out of your local DNS log.
`-sL`	List scan	Sends **no packets** to targets; only does reverse DNS to list hosts. Names can reveal a host's purpose or location.

SECTION 4

Advanced Scanning Options

NOTE Many of these scans require root or sudo.

Option	Scan	How it works / what to remember
`-sS`	TCP SYN scan	Default for **privileged** users. Sends SYN and listens for the reply without completing the handshake ("half-open" or "stealth"), so some systems do not log it. Stealth is not guaranteed; modern IDS and firewalls detect it. Faster and more accurate than -sT.
`-sT`	TCP connect scan	Default for **non-privileged** users. Uses the OS TCP/IP stack to make full connections. Slower, less accurate, not stealthy.
`-sU`	UDP scan	Needed for DNS, DHCP, SNMP and other UDP services. Slower than TCP because UDP behaves differently and many hosts rate-limit responses. Combine with TCP: -sS -sU.
`-sN`	TCP NULL scan	Sends packets with **no flags** set (header = 0). Tries to provoke a response from firewalled hosts; results are often open|filtered.
`-sF`	TCP FIN scan	Sets only the **FIN** bit. Another unexpected-packet technique.
`-sX`	Xmas scan	Sets **URG, FIN and PSH** ("lit up like a Christmas tree").
`-sA`	TCP ACK scan	Detects **firewall filtering**. RST back means *unfiltered*; no response means *filtered*. It does not say whether ports are open or closed.
`--scanflags`	Custom TCP scan	Choose your own flags, e.g. --scanflags SYNURG or FINACK (no spaces). Flags: SYN, ACK, PSH, URG, RST, FIN.
`-sO`	IP protocol scan	Lists which IP protocols (ICMP=1, TCP=6, UDP=17, ...) the host supports.

TIP NULL, FIN and Xmas scans do not work on every system, and Nmap often cannot decide the port state (open|filtered).

SECTION 5

Port Scanning Options

There are 65,535 ports, but Nmap scans only the **1,000 most common** by default to save time. These options change that.

Option	What it does
`-F`	Fast scan: only the **top 100** ports.
`-p 80 / -p 20-25,80,443`	Scan specific ports, lists or ranges.
`-p smtp,http`	Scan by **service name** (must exist in nmap-services). Wildcards work: -p "http*" (quote them).
`-sU -sT -p U:161,T:80`	Choose ports per protocol with U: and T: prefixes. Nmap scans TCP only unless you also give scan types.
`-p- (or -p "*")`	Scan **all 65,535 ports**. Finds services on obscure ports. Add -sU -sT to include UDP (very slow).
`--top-ports N`	Scan the N highest-ranked ports (e.g. 10, 50, 500).

Option	What it does
`-r`	Scan ports **sequentially**. By default Nmap randomises port order, which helps evade firewalls and IPS. Output is always sorted; add -v to see real-time order.
`--open`	Only show open ports.

SECTION 6

Operating System and Service Detection

Nmap identifies OS and software versions by analysing target responses, called **TCP/IP fingerprinting**. It is accurate but not an exact science.

Option	What it does
`-O`	OS detection. Needs at least **one open and one closed port** on the target. --osscan-limit skips hosts that do not qualify; --max-os-tries sets attempts (default 5).
`--osscan-guess (or --fuzzy)`	Force Nmap to guess; shows several matches with confidence percentages.
`-sV`	Service version detection: identifies the application and version on each open port.
`--version-intensity 0-9`	Default is 7. Lower is faster but misses services; 9 tries harder but is slower.
`--allports`	With -sV, do not skip ports 9100-9107, which Nmap avoids by default because network printers may print garbage.
`--version-trace`	Verbose output for debugging version scans (pipe to more or redirect to a file).

- If Nmap cannot identify the OS it prints a **TCP/IP fingerprint**. Submit it at nmap.org/submit/ to improve the database.

SECTION 7

Timing Options

Speed things up on fast networks, or slow them down for accuracy and to avoid detection. Timing values take **ms, s, m, h** suffixes. In Nmap 6 the default unit is **seconds** (milliseconds in Nmap 5 and earlier). So 300000ms = 300s = 300 = 5m.

Timing templates: -T0 to -T5

Template	Name	Use
`-T0`	paranoid	Extremely slow
`-T1`	sneaky	Avoiding intrusion detection systems
`-T2`	polite	Unlikely to disturb the target
`-T3`	normal	Default
`-T4`	aggressive	Faster on speedy networks
`-T5`	insane	Extremely fast and aggressive; may cost accuracy

Fine-grained timing options

Option	Effect
`--min-parallelism / --max-parallelism`	Min or max number of parallel port-scan operations. Too high a minimum can give inaccurate results; --max-parallelism 1 is slow and gentle.
`--min-hostgroup / --max-hostgroup`	Min or max number of targets scanned in parallel. A smaller max reduces network load and IDS red flags.
`--initial-rtt-timeout`	Initial round-trip timeout (default 1000 ms). Higher reduces retransmissions; too low gives bad results.
`--max-rtt-timeout`	Upper limit for a response (default 10 s). Typical range: 100 ms (fast networks) to 10000 ms (slow or unreliable).
`--max-retries`	Max probe retransmissions. More retries are slower but more accurate.
`--ttl`	Sets IP time-to-live (hop limit). Helps on distant or slow links.
`--host-timeout`	Give up on slow hosts after this time. **Warning:** no results are shown for a host that exceeds it, even if open ports were found.
`--scan-delay / --max-scan-delay`	Minimum or maximum pause between probes. Useful against rate limiting and IDS (e.g. --scan-delay 1s).
`--min-rate / --max-rate`	Minimum or maximum packets per second. --max-rate 0.1 sends one packet every 10 seconds. A min rate that is too high reduces accuracy.
`--defeat-rst-ratelimit`	Speeds scans of targets that rate-limit RST packets, but can be inaccurate. Rarely needed.

SECTION 8

Evading Firewalls

Firewalls and intrusion prevention systems try to stop tools like Nmap from getting an accurate picture. These options test how well a defence holds up. Use them only in **authorised** security audits.

Option	Technique
`-f`	Fragment probes into tiny **8-byte** packets; may fool older or misconfigured firewalls. Some OSes need --send-eth too.
`--mtu N`	Custom fragment size. Must be a **multiple of 8**.
`-D RND:n / -D d1,d2`	**Decoys**: spoofed packets from other addresses make the scan appear to come from many sources. Too many decoys cause congestion, and spoofed traffic may be filtered.
`-sI zombie`	**Idle zombie scan**: bounces the scan off an idle host using predictable IP ID sequence numbers. The zombie must truly be idle (idle printers work well). Combine with -Pn to avoid even the initial ping.
`--source-port / -g`	Fix the source port. Exploits firewalls that blindly trust traffic from ports such as 20 (FTP), 53 (DNS) or 67 (DHCP).
`--data-length N`	Append random data to probes; may get replies that empty packets do not. Over 1400 bytes may exceed MTU.
`--randomize-hosts`	Scan targets in random order to avoid IDS pattern detection; combine with timing options.
`--spoof-mac 0|vendor|MAC`	Spoof your MAC address: 0 = random, a vendor name (Apple, Dell...), or a specific MAC.
`--badsum`	Send packets with bad checksums. Only a poorly designed system replies. No response is the normal, healthy result.

SECTION 9

Output Options

Save results to files for later analysis, searching, or comparison with Ndiff.

Option	Format	Notes
`-oN file`	Normal text	Overwrites an existing file unless --append-output is used.
`-oX file`	XML	Needed for Ndiff. Paths are hard-coded to the creating system; use --webxml for portability or --no-stylesheet to omit the stylesheet reference.
`-oG file`	Grepable	One host per line; search with grep (e.g. grep "Windows Server 2003" scan.txt). grep is built in on Unix/Linux/Mac only.
`-oA basename`	All three	Creates .nmap (text), .gnmap (grepable) and .xml files.
`-oS file`	"133t" output	Script-kiddie text; included as a joke.

SECTION 10

Troubleshooting and Debugging

Option	Purpose
`-h / man nmap`	Quick option summary / full manual (man is Unix, Linux, Mac only).
`-V`	Show Nmap version and compile info. Always run the latest version when troubleshooting.
`-v, -vv`	Verbose output showing what is going on during the scan.
`-d[1-9]`	Debugging output; -d1 is least and -d9 is most.
`--reason`	Why each port has its state: syn-ack means open; conn-refused or reset usually means closed; no response usually means filtered; port-unreach is an ICMP unreachable message.
`--packet-trace`	Show every packet sent and received. Pipe to more or redirect to a file.
`--iflist`	Show local interfaces and routes.
`-e interface`	Force a specific network interface (e.g. -e eth0) on multi-interface machines.

TIP Related OS tools: ifconfig (Unix/Linux), ipconfig (Windows), netstat. Wireshark pairs well with --packet-trace.

SECTION 11

Zenmap (GUI)

Zenmap is the cross-platform graphical front end for Nmap (Windows, Mac OS X, Unix/Linux).

- **Install:** included with Nmap on Windows and Mac (Mac needs an X11 server such as Xquartz). On Linux: `apt-get install zenmap` (Debian/Ubuntu) or `yum install nmap-frontend` (Fedora/Red Hat/CentOS).
- **Three steps to scan:** enter a target, choose a scanning profile, press Scan.
- **Profiles:** built-in profiles for common scans; build your own with Profile > New Profile (Ctrl+P) in the profile editor, which builds the command line for you.
- **Tabs:** Nmap Output (raw output), Ports/Hosts, Topology (interactive network map, needs a traceroute profile), Host Details, Scans (history).
- **Topology maps** can be saved as PNG, PDF, SVG or PostScript.
- **Compare Results:** Tools > Compare Results (Ctrl+D), colour-coded differences; can import Nmap XML files.
- **Save scans:** Scan > Save Scan (Ctrl+S).

SECTION 12

Nmap Scripting Engine (NSE)

NSE runs scripts (written in **Lua**) that go beyond port scanning: extra info, vulnerability detection and more. There are 300+ built-in scripts documented at nmap.org/nsedoc/.

> **WARNING** NSE uses aggressive techniques that can occasionally cause downtime or data loss, and its vulnerability and exploitation features can cause legal trouble without permission.

Goal	Command
Run one script	nmap --script whois-ip.nse [target]
Run several / wildcard	nmap --script script1,script2 [target] or nmap --script "smtp*" [target]
Run by category	nmap --script default [target] (shortcut: -sC)
Several categories	nmap --script malware,vuln [target]
Boolean expressions	--script "default and safe" | "default or safe" | "not intrusive"
Script arguments	--script-args (see nsedoc for each script's arguments)
Script help	nmap --script-help [script or category]
Trace scripts	nmap --script [x] --script-trace [target] (redirect output to a file)
Update script DB	nmap --script-updatedb (needed after adding or removing scripts)

Script categories

Category	Meaning
`all`	Every available script
`auth`	Authentication-related
`default`	Basic default set (-sC)
`discovery`	In-depth information gathering
`external`	Contacts external sources (e.g. whois)
`intrusive`	May be considered intrusive by the target
`malware`	Checks for backdoors and malware
`safe`	Basic, non-intrusive
`vuln`	Checks for commonly exploited vulnerabilities

Useful everyday scripts

Script	Use
`dhcp-discover.nse`	Information about a DHCP server
`dns-nsid.nse`	Information about a DNS server
`ftp-anon.nse`	Check whether an FTP server allows anonymous access
`http-errors.nse`	Crawl a site and list errors
`http-google-malware.nse`	Is the site on Google's malware blacklist?
`http-headers.nse`	List a web server's HTTP headers
`mysql-info.nse`	Information about MySQL servers
`nbstat.nse`	NetBIOS info for Windows/Samba
`ntp-info.nse`	Information about an NTP server
`smb-os-discovery.nse`	Information about an SMB host
`smtp-commands.nse`	Gather info on an SMTP server
`smtp-open-relay.nse`	Test for an open SMTP relay
`snmp-info.nse`	Information from a system running SNMP
`whois-ip.nse`	Whois lookup on an IP (older Nmap: whois.nse)

Scripts live in /usr/share/nmap/scripts/ on most Unix-like systems and C:\Program Files\Nmap\scripts on Windows.

SECTION 13

Ndiff

Ndiff compares two Nmap **XML** output files and highlights changes, which is useful for spotting new or changed ports over time. It also exists as Compare Results inside Zenmap.

Command	Effect
`ndiff scan1.xml scan2.xml`	Shows differences only. A minus sign marks the first file and a plus sign marks the second.
`ndiff -v scan1.xml scan2.xml`	Verbose: shows all lines of both files with differences highlighted.
`ndiff --xml scan1.xml scan2.xml`	XML output of the differences, good for feeding other programs. Redirect with > ndiff.xml.

Workflow: `nmap -oX scan1.xml [target]`, scan again later with -oX scan2.xml, then run ndiff.

SECTION 14

Nping

Nping is a modern replacement for ping and for Hping (abandoned in 2005): "ping on steroids". It prints both **SENT** and **RCVD** packets, and works best with root privileges (default on Windows).

Option	Effect
`nping [target]`	Sends 5 ICMP echo requests (1 per second by default) and prints a summary.
`-H`	Hide sent packets (traditional ping-style output).
`-q`	Quiet: hide all packets, summary only. Best for stress tests.
`-c N`	Packet count. -c 0 runs until Ctrl+C.
`--rate N`	Pings per second (default 1). With a large -c this can flood or stress-test a link; compare Lost % to measure capacity.
`-N`	Ignore replies, reducing load on your own system when flooding.
`--delay T`	Delay between probes (ms, s, m, h; decimals allowed; default seconds).
`--data-length N`	Random payload per packet for load testing. Custom data via --data or --data-string.
`--tcp / --udp`	Ping with TCP (default port 80) or UDP (default port 53) instead of ICMP. Helps check hosts behind NAT or firewalls that drop ICMP.
`-p ports`	Specific ports; needs --tcp or --udp. Multiple ports are alternated round-robin.
`--arp`	ARP ping on the local network. A host with a firewall that drops ICMP, TCP and UDP must still answer ARP, and you also learn its MAC address.
`multiple targets`	Same syntax as Nmap (list, range, CIDR). Pinged round-robin; per-host statistics at the end.

Other Nping options: -h, -V, -d[1-6], -v[-4 to 4], -e interface, -g source port, --flags, -6, --echo-server and --echo-client [passphrase].

SECTION 15

Ncat

Ncat is the modern "Swiss Army knife" for TCP/IP and replaces the unmaintained **Netcat** (since Nmap 5). It can act as a client or server for almost any protocol and is handy for troubleshooting and auditing.

Task	Commands
Test a web server	ncat -C [target] 80 (HTTPS: ncat -C --ssl [target] 443). Type HEAD HTTP1.0 and press Enter twice to see response headers; GET HTTP1.0 returns the page. End with Ctrl+D. For virtual hosts add a Host: header.
Test an SMTP server	ncat [target] 25. Expect a 220 banner, send HELO test and get 250, then QUIT and get 221.
Transfer a file	Receiver: ncat -l > test.png Sender: ncat --send-only [target] < test.png. Verify with md5sum.
Ad hoc chat	Host: ncat -l Guest: ncat [host]. Add --chat on the listener for multi-user chat with unique IDs.
Ad hoc web server	ncat -l 80 < web.server where the file holds an HTTP/1.0 200 OK line plus minimal HTML.

SECTION 16

Tips and Tricks

- **Combine options** freely to build custom scans, e.g. `nmap --reason -F --open -T3 -O scanme.nmap.org`.
- **--stats-every [time]** prints scan progress periodically (s, m or h).
- **Runtime keys** during a scan: v/V raise/lower verbosity; d/D raise/lower debugging; p/P turn packet tracing on/off; ? shows help; any other key prints a status message.
- **Remote check:** nmap-online.com lets you scan your network from outside through a browser.
- **scanme.nmap.org** is a legitimate practice target; be polite and do not scan it aggressively or hundreds of times a day.
- **Wireshark** (free packet analyser) shows each packet while Nmap runs.
- **Resources:** nmap.org/book/man.html, nmap.org/nsedoc/, seclists.org, sectools.org, nmapcookbook.com.

Conclusion from the author

Nmap is for discovering (nmap), troubleshooting (ncat) and stress testing (nping). Security takes constant monitoring, patching and best-practice configuration, and it is an **arms race**: attackers use the same tools plus more.

SECTION +

Quick Cheat Sheet

Need	Command
Basic scan	nmap [target]
Whole subnet, hosts up only	nmap -sn 192.168.1.0/24
Skip host discovery	nmap -Pn [target]
Fast (top 100 ports)	nmap -F [target]
All ports	nmap -p- [target]
TCP and UDP	nmap -sS -sU [target]
OS + version + scripts + traceroute	nmap -A [target]
Service versions	nmap -sV [target]
OS detection	nmap -O [target]
Is there a firewall?	nmap -sA [target]
Only open ports, with reason	nmap --open --reason [target]
Default NSE scripts	nmap -sC [target]
Slow and quiet	nmap -T1 --max-rate 1 [target]
Save everything	nmap -oA results [target]
Compare two scans	ndiff scan1.xml scan2.xml
Ping with TCP on port 25	nping --tcp -p 25 [target]
Listen on a port	ncat -l [port]

Revision questions

1. Name the four TCP/IP layers and one protocol from each.
2. How many ports exist, and how many does Nmap scan by default? How do you change that?
3. List the six port states. What does the -sA scan tell you, and what can't it tell you?
4. Why is a SYN scan called "stealthy", and why is it not truly invisible?
5. When would you use -Pn? What did it change in Nmap 6 compared to Nmap 5?
6. What is the difference between -sS and -sT, and which one is the default for non-root users?
7. Why are three different port states in one scan suspicious?
8. What does the -T template range from and what is the default?
9. How does an idle zombie scan work, and what makes a good zombie?
10. Which output option creates three files at once? Which format does Ndiff need?
11. What does -sC do, and what is the NSE category syntax for "default but not intrusive"?
12. Why would you use nping --arp rather than a normal ping on a LAN host with a firewall?

Answers: see Sections 0 to 9 and 12 to 14 above.